
INCIDENT RESPONSE PLAYBOOK

Scenariusz: Zgubiony telefon służbowy z dostępem do poczty

Wersja: 1.0

Data: 15.04.2026

Standard: NIST SP 800-61 Rev. 2

1. PRZYGOTOWANIE (Preparation)

1.1 Zabezpieczenia techniczne (PRZED incydem):

- ☐ Pełne szyfrowanie dysku telefonu (FileVault/BitLocker/Android Encryption)
- ☐ Wymuszenie silnego PIN/hasła (min. 8 znaków) + biometria
- ☐ Automatyczna blokada ekranu po 2 minutach bezczynności
- ☐ Włączenie MDM (Mobile Device Management) z możliwością zdalnego wipe
- ☐ Wymuszenie szyfrowania w aplikacji pocztowej
- ☐ Backup danych telefonu w bezpiecznej lokalizacji

1.2 Polityki i procedury:

- ☐ Polityka BYOD/CYOD określająca zasady używania telefonu służbowego
- ☐ Procedura zgłaszania zagubienia/kradzieży (kontakt, czas reakcji)
- ☐ Lista krytycznych kontaktów (IT Security, Helpdesk, kierownik)
- ☐ Szkolenie pracowników: co robić gdy telefon zostanie zgubiony

1.3 Przygotowanie dokumentacji:

- ☐ Rejestr urządzeń mobilnych (IMEI, numer, przypisany użytkownik)
- ☐ Lista aplikacji i dostępów na każdym urządzeniu
- ☐ Procedura eskalacji w zależności od poziomu dostępu

2. WYKRYCIE I ANALIZA (Detection & Analysis)

2.1 Zgłoszenie incydentu:

Pracownik NATYCHMIAST zgłasza utratę telefonu:

- Kanał: Telefon do IT Helpdesk: [NUMER] lub email: security@firma.pl
- Czas: maksymalnie 30 minut od stwierdzenia utraty

2.2 Informacje do przekazania przy zgłoszeniu:

- ☐ Imię, nazwisko, stanowisko zgłaszającego
- ☐ Data i godzina ostatniego kontaktu z telefonem

- ☐ Miejsce prawdopodobnej utraty (biuro/zewnątrz/transport publiczny)
- ☐ Czy telefon był zabezpieczony PIN/hasłem
- ☐ Czy istnieje podejrzenie kradzieży
- ☐ Jakie dane/aplikacje były zainstalowane (email, VPN, dokumenty)

2.3 Weryfikacja incydentu przez IT Security:

- ☐ Sprawdzenie logów MDM - ostatnia lokalizacja, ostatnia aktywność
- ☐ Sprawdzenie logów email - ostatnie logowanie, podejrzane aktywności
- ☐ Ocena poziomu ryzyka (typ danych, stanowisko użytkownika)
- ☐ Klasyfikacja incydentu: NISKI / ŚREDNI / WYSOKI / KRYTYCZNY

3. POWSTRZYMANIE, USUNIĘCIE I ODTWORZENIE (Containment, Eradication & Recovery)

3.1 NATYCHMIASTOWE działania (w ciągu 1 godziny):

KROK 1: Izolacja dostępu

- ☐ Zablokowanie karty SIM u operatora
- ☐ Zmiana hasła do konta email użytkownika
- ☐ Wymuszenie wylogowania ze wszystkich sesji email (revoke tokens)
- ☐ Zablokowanie dostępu VPN przypisanego do użytkownika

KROK 2: Próba lokalizacji i zdalnego wipe

- ☐ Sprawdzenie lokalizacji przez MDM/Find My Device
- ☐ Jeśli telefon online: natychmiastowe zdalne wyczyszczenie (remote wipe)
- ☐ Jeśli telefon offline: wydanie polecenia wipe (wykona się po połączeniu)
- ☐ Oznaczenie telefonu jako "zgubiony" w systemie MDM

KROK 3: Monitoring

- ☐ Monitoring logów email - czy ktoś próbuje się logować
- ☐ Monitoring logów VPN - nieautoryzowane próby dostępu
- ☐ Alert dla SOC na podejrzane aktywności z konta użytkownika

3.2 Działania krótkoterminowe (24-48h):

- ☐ Analiza, jakie dane były dostępne na telefonie
- ☐ Sprawdzenie, czy doszło do nieautoryzowanego dostępu
- ☐ Jeśli telefon odnaleziony: weryfikacja integralności przed ponownym użyciem
- ☐ Jeśli telefon NIE odnaleziony: raport do przełożonego i RODO (jeśli dane osobowe)

3.3 Odtworzenie (Recovery):

- ☐ Wystawienie nowego telefonu służbowego
- ☐ Rekonfiguracja MDM i polityk bezpieczeństwa
- ☐ Przywrócenie danych z backupu (jeśli dotyczy)

- ☐ Ponowne przeszkolenie użytkownika z procedur bezpieczeństwa

4. DZIAŁANIA PO INCYDENCIE (Post-Incident Activity)

4.1 Dokumentacja i raport:

- ☐ Sporządzenie szczegółowego raportu z incydentu (timeline, działania, wyniki)
- ☐ Ocena, czy incydent został obsłużony zgodnie z procedurą
- ☐ Oszacowanie strat/kosztów (sprzęt, dane, czas pracy)
- ☐ Raport do kierownictwa (jeśli wysoki/krytyczny poziom ryzyka)

4.2 Analiza przyczyn i Lessons Learned:

- ☐ Dlaczego doszło do utraty telefonu?
- ☐ Czy zabezpieczenia techniczne zadziałały prawidłowo?
- ☐ Czy czas reakcji był odpowiedni?
- ☐ Co można poprawić w procedurach?

4.3 Usprawnienia i aktualizacje:

- ☐ Aktualizacja procedur (jeśli wykryto luki)
- ☐ Dodatkowe szkolenie pracowników (jeśli potrzebne)
- ☐ Wdrożenie dodatkowych kontroli technicznych (np. geo-fencing)
- ☐ Przegląd polityki MDM i dostępów

4.4 Komunikacja:

- ☐ Poinformowanie zespołu IT o wnioskach
- ☐ Przypomnienie wszystkim pracownikom o procedurach (jeśli szerszy problem)
- ☐ Aktualizacja FAQ/Bazy wiedzy

KONTAKTY AWARYJNE

IT Helpdesk: [NUMER] / helpdesk@firma.pl
IT Security Team: security@firma.pl
Incident Manager: [IMIĘ NAZWISKO] / [NUMER]
Operator sieci: [NUMER HOTLINE OPERATORA]

KONIEC DOKUMENTU